Unit IV: Authorization

Dr. Mukti Padhya

Assistant Professor, NFSU

Identification, Authentication & Authorization

Identification: This is an action in which the user (untrusted party) declares his identity. Identification is the ability to identify uniquely a user of a system or an application that is running in the system

Authentication: This is an action(s) to prove that the user is who he claims to be. Authentication is the act of proving the identity of a computer system user

Authorization: This action(s) is required to determine which actions a specific user can perform. Authorization is the function of specifying access rights/privileges to resources

Identification

- Here the system has to trust an untrusted party and hence may appear irrelevant.
- However for authentication, proper identification is mandatory
- Once identification is established, the system has to validate that one individual
- E.g. Automatic identification of personnel by scanning the badge at the entry gate instead of manual identification by security personnel to prevent delay and long queues at the entrance

Authentication

- This is the most attacked process and is the weakest link in the security chain
- Authentication can be performed in three different ways
  - Something you know - This is a way to identify a user using something like a PIN, a password, or a passphrase
  - Something you have - This is a way to identify a user using something like a smart card or a badge
  - Something you are - This is a way to identify a user using biometrical characteristics of the user

MFA

- The three authentication mechanisms have inherent weaknesses and hence cannot be used alone
- Each option has different type of weakness and they can be combined to create a secure system
- Hence Multi Factor Authentication is used to provide two or more verification factors to gain access to a resource
- MFA reduces likelihood of a successful cyber attack
- Multifactor authentication combines two or more independent credentials: what the user knows, such as a password; what the user has, such as a security token; and what the user is, by using biometric verification methods

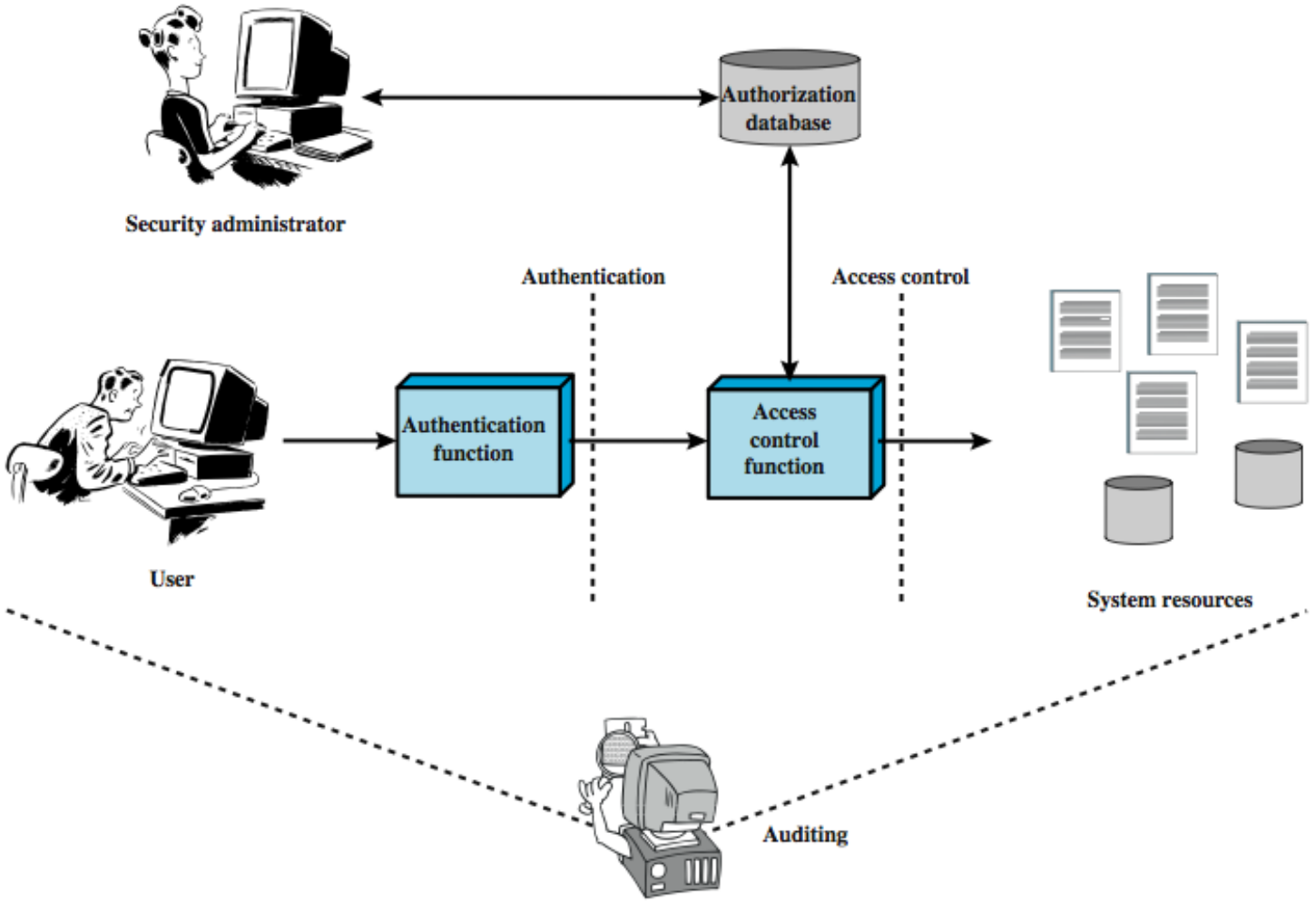
Authorization

- The goal of authorization is to be sure that the given user has clearance to do what he is asking to do
- There are multiple ways to grant privileges to a user, based on the access control model the system uses
- The primary goal of controls is to ensure the confidentiality and integrity of data by disallowing unauthorized access by authorized or unauthorized subjects
- The main access control models are
- Mandatory Access Control (MAC)
- Discretionary Access Control (DAC)
- Role-based Access Control (RBAC)
- Attribute-based Access Control (ABAC)

Access Control

- “The prevention of unauthorized use of a resource, including the prevention of use of a resource in an unauthorized manner“
- Central element of computer security
- Assume have users and groups
  - authenticate to system
  - assigned access rights to certain resources on system

Access Control Principles



Access Control Principles

The concept of access control implements a security policy that specifies who or what may have access to each specific system resource and the type of access that is permitted in each instance. In addition to access control, this broader context involves the following entities and functions:

- **Authentication:** The verification an identity claimed by or for a system entity.
- **Authorization:** The granting of a right or permission to a system entity to access a system resource. This function determines who is trusted for a given purpose.
- **Audit:** An independent review and examination of system records and activities in order to test for adequacy of system controls, to ensure compliance with established policy and operational procedures, to detect breaches in security, and to recommend any indicated changes in control, policy and procedures.

An access control mechanism mediates between a user (or a process executing on behalf of a user) and system resources, such as files and database. The system must first authenticate a user seeking access. Then, the access control function determines if the specific requested access by this user is permitted. A security administrator maintains an authorization database that specifies what type of access to which resources is allowed for this user. The access control function consults this database to determine whether to grant access. An auditing function monitors and keeps a record of user accesses to system resources. All operating systems have at least a rudimentary, and in many cases a quite robust, access control component. Particular applications or utilities, such as a database management system, also incorporate access control functions.

Access control policies

- **Discretionary** access control (DAC): based on the identity of the requestor and access rules
- **Mandatory** access control (MAC): based on comparing security labels with security clearances (mandatory: one with access to a resource cannot pass to others)
- **Role-based** access control (RBAC): based on user roles
- **Attribute-based** access control: based on the attributes of the user, the resources and the current environment

Access Control Requirements

- **Reliable input:** it assumes that a user is authentic; thus, an authentication mechanism is needed as a front end to an access control system. Other inputs to the access control system must also be reliable.
- **Support for fine and coarse specifications:** fine-grained specifications allow access regulated at the level of individual fields / records in files; and each individual access by a user rather than a sequence of accesses. System administrators should also be able to choose coarse-grain specification for some classes of resource access.
- **Least privilege:** it should be implemented so that each system entity is granted the minimum system resources and authorizations needed to do its work. This principle tends to limit damage that can be caused by an accident, error, or unauthorized act.
- **Separation of duty:** should divide steps in a system function among different individuals, so as to keep a single individual from subverting the process.
- **Open and closed policies:** a closed policy only allows accesses that are specifically authorized; an open policy allows all accesses except those expressly prohibited.
- **Administrative policies:** to specify who can add, delete, or modify authorization rules, and also need access control and other control mechanisms to enforce these administrative policies.

Access Control Elements

The basic elements of access control are: subject, object, and access right.

- A **subject** is an entity capable of accessing objects, usually a process. Any user or application actually gains access to an object by means of a process that represents it. A subject is typically held accountable for the actions they have initiated, and an audit trail may be used to associate with a subject and security-relevant actions performed on an object. Basis access control systems typically define three classes of subject:
  - **Owner:** This may be the creator of a resource, such as a file. For system resources, ownership may belong to a system administrator. For project resources, a project administrator or leader my be assigned ownership.
  - **Group:** In addition to the privileges assigned to an owner, a named group of users may also be granted access rights, such that membership in the group is sufficient to exercise these access rights.
  - **World:** The least amount of access is granted to users who are able to access the system but are not included in the categories owner and group for this resource.

- An **object** is any resource to which access is controlled. In general, and object is an entity used to contain and/or receive information. Examples include records, blocks, pages, segments, files, portions of files, directories, directory trees, mailboxes, messages, and programs. The number and types of objects to be protected by an access control system depends on the environment in which access control.

- An **access right** describes the way in which a subject may access an object. Access rights could include the following: read, write, execute, delete, create, search.

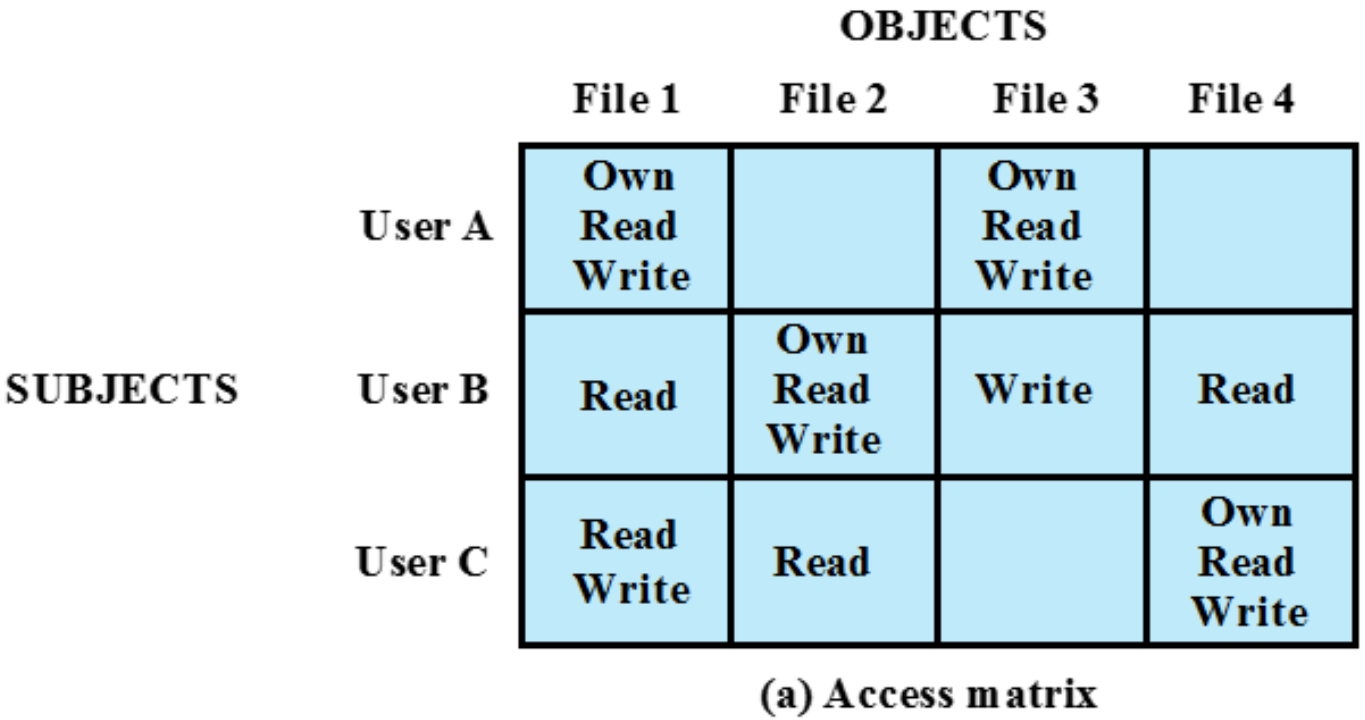
Discretionary Access Control

- Often provided using an access matrix
  - lists subjects in one dimension (rows)
  - lists objects in the other dimension (columns)
  - each entry specifies access rights of the specified subject to that object
- Access matrix is often sparse
- Can decompose by either row or column

Discretionary Access Control

- For discretionary access control, a general approach to access control as exercised by an operating system or a database management system is that of an **access matrix.**
- One dimension of the matrix consists of identified subjects that may attempt data access.
- Typically, this list will consist of individual users or user groups, although access could be controlled for terminals, hosts, or applications instead of or in addition to users.
- The other dimension lists the objects that may be accessed. At the greatest level of detail, objects may be individual data fields.
- More aggregate groupings, such as records, files, or even the entire database, may also be objects in the matrix.
- Each entry in the matrix indicates the access rights of that subject for that object. In practice, an access matrix is usually sparse and is implemented by decomposition in one of two ways, as we show on the next slide.

An access matrix



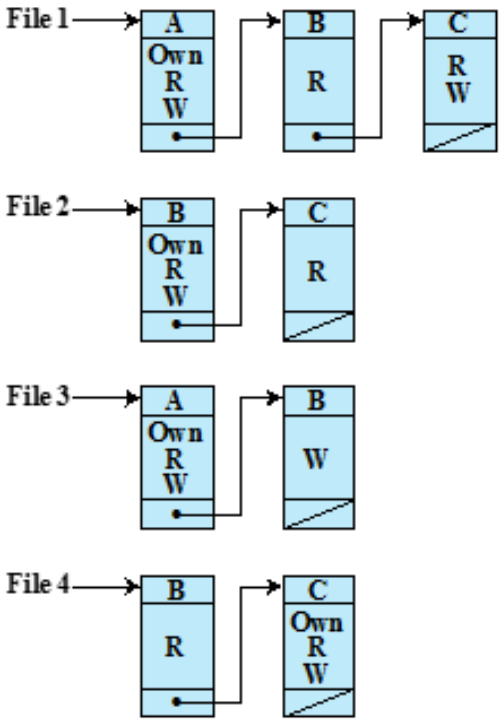
		OBJECTS			
		File 1	File 2	File 3	File 4
SUBJECTS	User A	Own Read Write		Own Read Write	
	User B	Read	Own Read Write	Write	Read
	User C	Read Write	Read		Own Read Write

(a) Access matrix

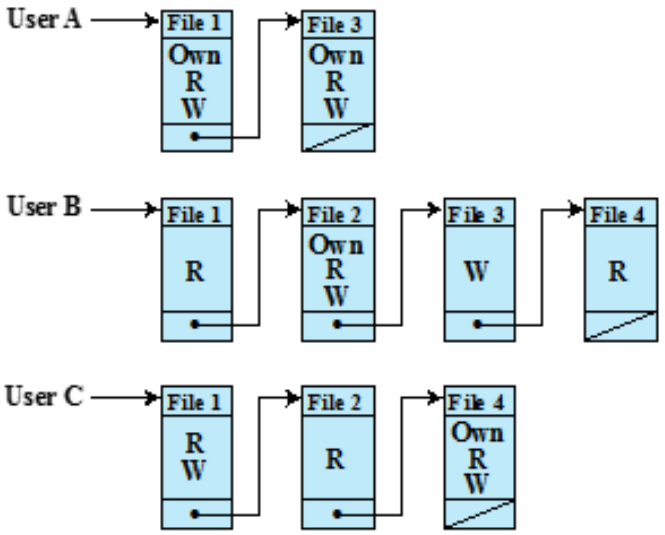
Access Control Structures

- Access control lists (decomposed by column)
- Capability tickets (decomposed by row)

Access matrix data structures



(b) Access control lists for files of part (a)



(c) Capability lists for files of part (a)

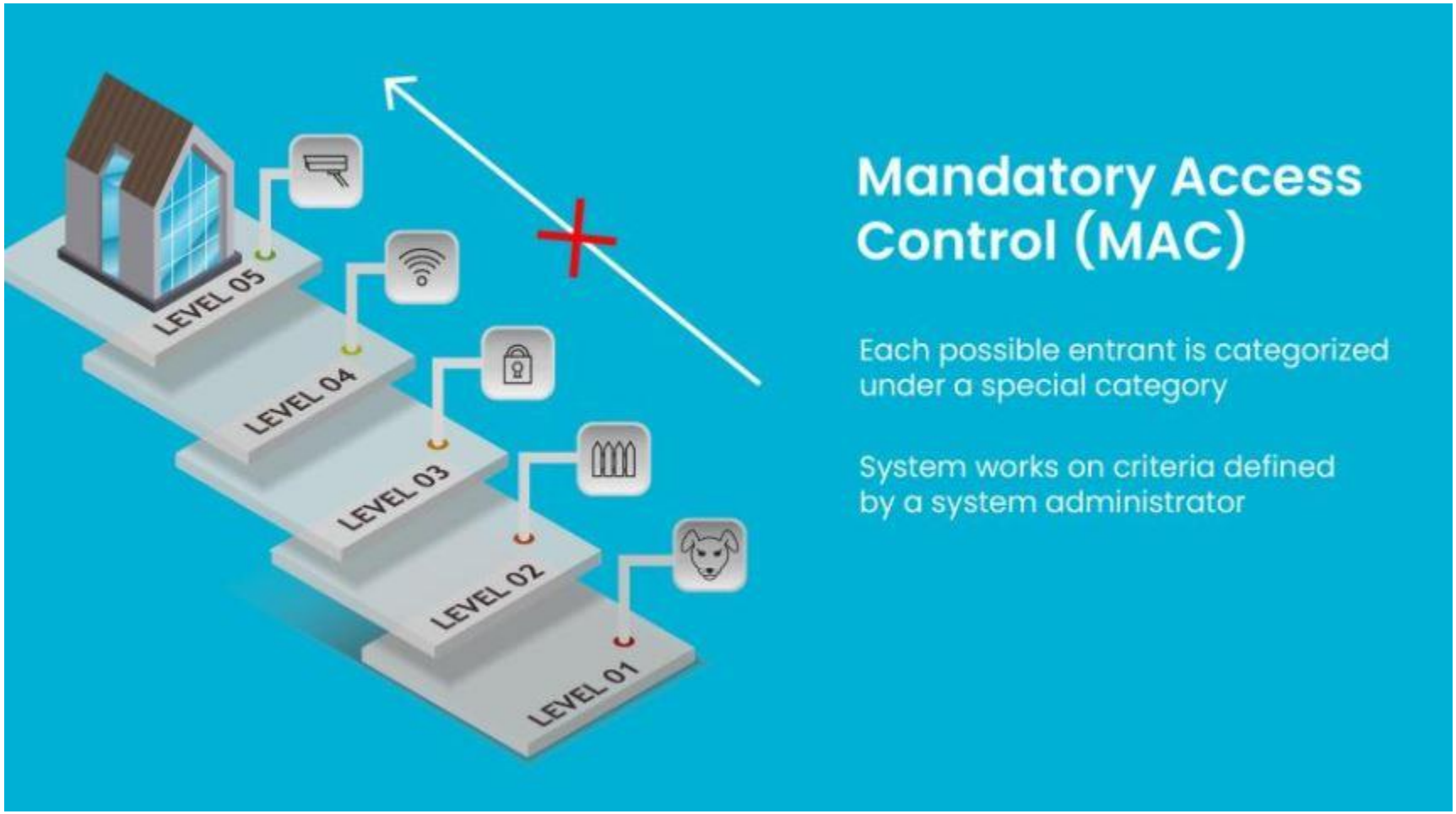
An Access Control Model

- Extend the universe of objects to include processes, devices, memory locations, subjects

		OBJECTS								
		subjects			files		processes		disk drives	
		S_1	S_2	S_3	F_1	F_1	P_1	P_2	D_1	D_2
SUBJECTS	S_1	control	owner	owner control	read *	read owner	wakeup	wakeup	seek	owner
	S_2		control		write *	execute			owner	seek *
	S_3			control		write	stop			

* - copy flag set

MAC –Mandatory Access Control



Advantages: Mandatory Access Control (MAC)



High-level data protection



Centralized Information



Privacy

Disadvantages: Mandatory Access Control (MAC)



Careful Setting-Up Process



Regular Update Required:



Lack of Flexibility

Bell-LaPadula Model, Step 1

- Security levels arranged in linear ordering
  - Top Secret: highest
  - Secret
  - Confidential
  - Unclassified: lowest
- Levels consist of *security clearance* $L(s)$
  - Objects have *security classification* $L(o)$

Example

security level	*subject*	*object*
Top Secret	Tamara	Personnel Files
Secret	Samuel	E-Mail Files
Confidential	Claire	Activity Logs
Unclassified	Ulaley	Telephone Lists

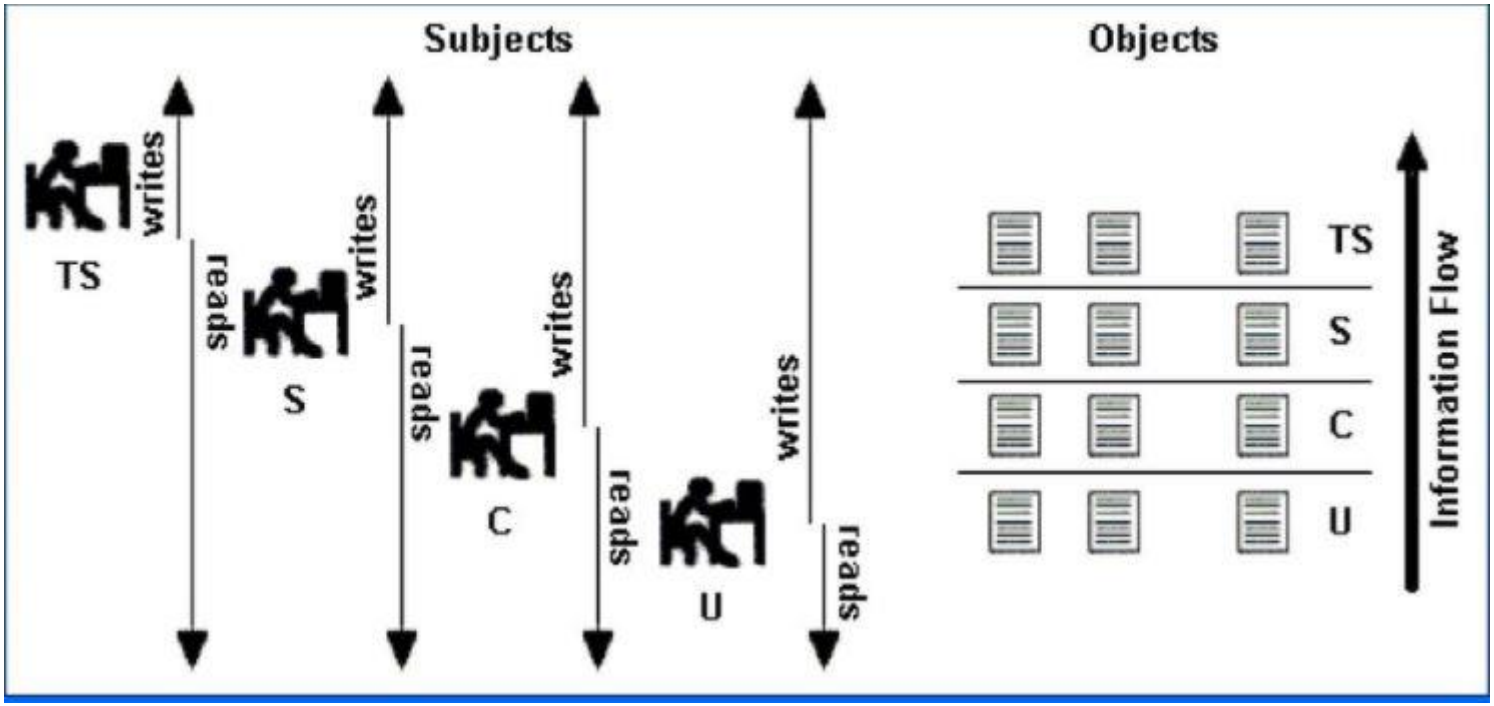
- Tamara can read all files
- Claire cannot read Personnel or E-Mail Files
- Ulaley can only read Telephone Lists

Reading Information

- Information flows *up*, not *down*
  - "Reads up" disallowed, "reads down" allowed
- Simple Security Condition (Step 1)
  - Subject *s* can read object *o* iff, $L(o) \leq L(s)$ and *s* has permission to read *o*
    - Note: combines mandatory control (relationship of security levels) and discretionary control (the required permission)
  - Sometimes called "no reads up" rule

Writing Information

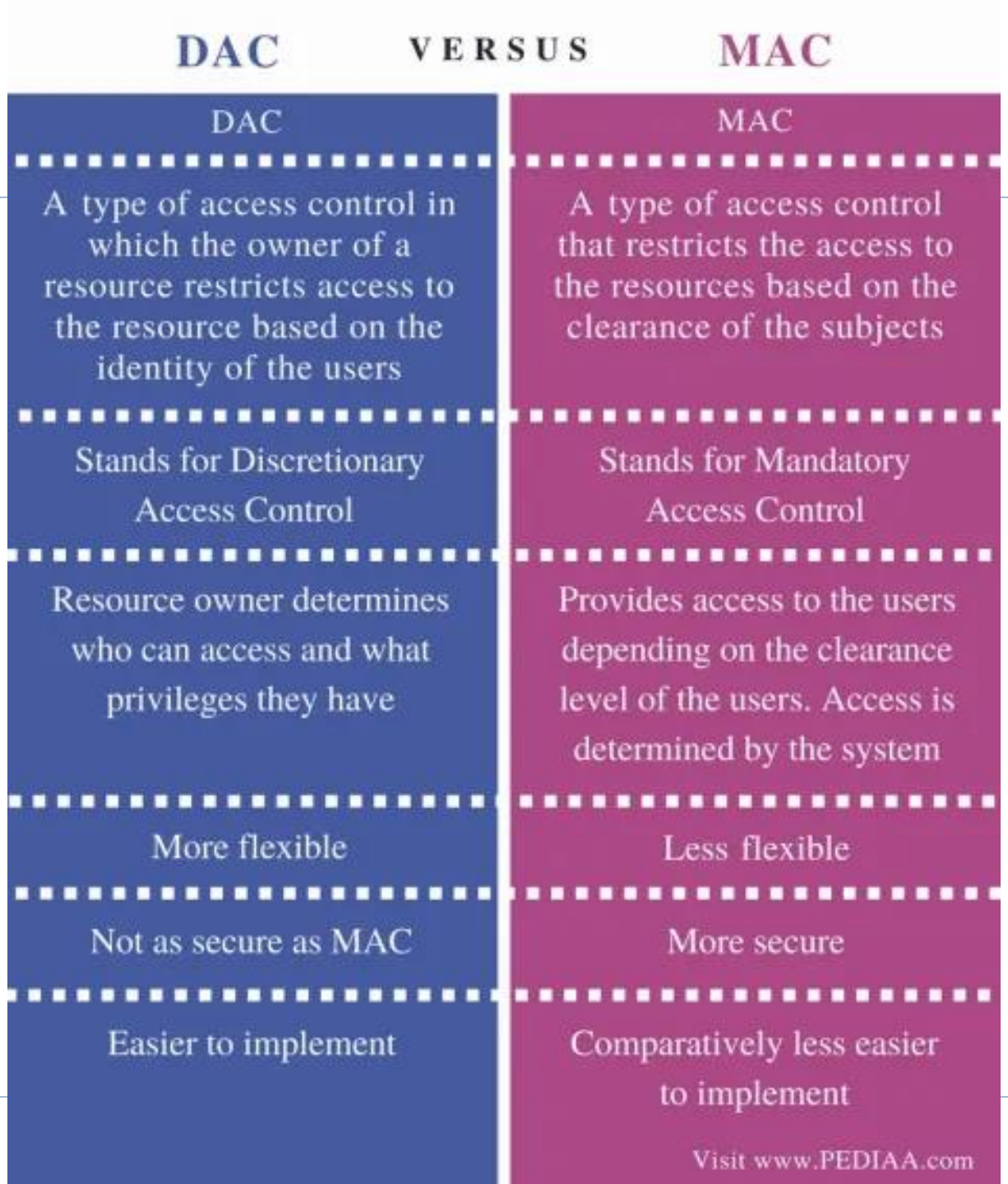
- Information flows up, not down
  - "Writes up" allowed, "writes down" disallowed
- *-Property (Step 1)
  - Subject *s* can write object *o* iff $L(s) \leq L(o)$ and *s* has permission to write *o*
    - Note: combines mandatory control (relationship of security levels) and discretionary control (the required permission)
  - Sometimes called "no writes down" rule


Subjects
Objects
TS
S
C
U
writes
reads
Information Flow

DAC vs. MAC

Characteristic	MAC	DAC
Access control enforced by	Administrators and operating system	Administrators and users
Form of access control policy	Confidentiality levels and clearances	Access-control lists with user identities
Flexibility	–	✓
Scalability	–	✓
Simplicity	–	✓
Maintenance	Hard	Easy
Implementation cost	High	Low
Granularity	High (admins adjust clearances for each user and object manually)	High (users can assign access rights for any other user or group)
Easy to use	–	✓
Security level	High	Low
Useful for	Government, military, law enforcement	Small and medium-sized companies
Trusted users	Only administrators	All users
Baseline for gaining access decisions	Tasks and objects that have their own IDs	Ownership and users IDs

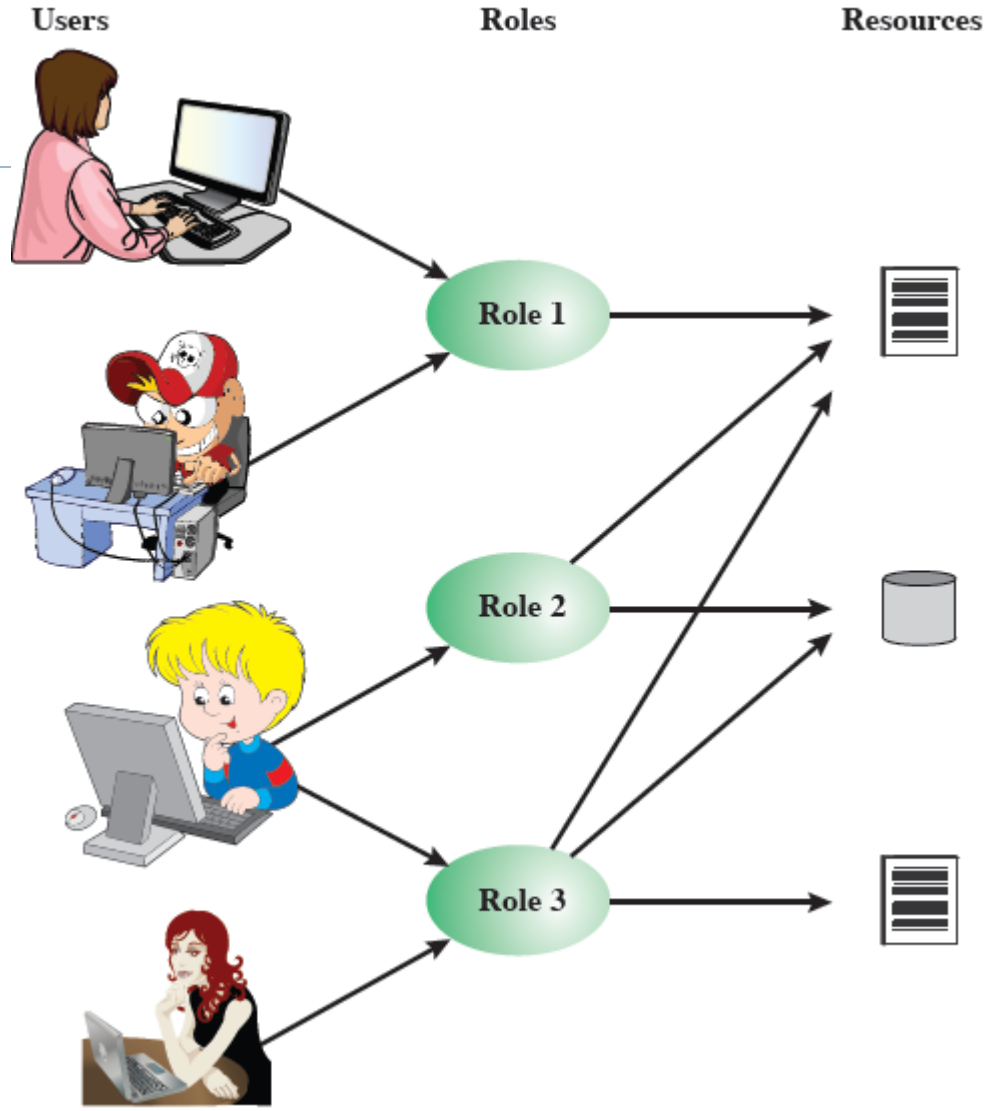



DAC VERSUS MAC
DAC
A type of access control in which the owner of a resource restricts access to the resource based on the identity of the users
Stands for Discretionary Access Control
Resource owner determines who can access and what privileges they have
More flexible
Not as secure as MAC
Easier to implement
MAC
A type of access control that restricts the access to the resources based on the clearance of the subjects
Stands for Mandatory Access Control
Provides access to the users depending on the clearance level of the users. Access is determined by the system
Less flexible
More secure
Comparatively less easier to implement
Visit www.PEDIAA.com

Role-Based Access Control

Access based on ‘role’, not identity

Many-to-many relationship between users and roles

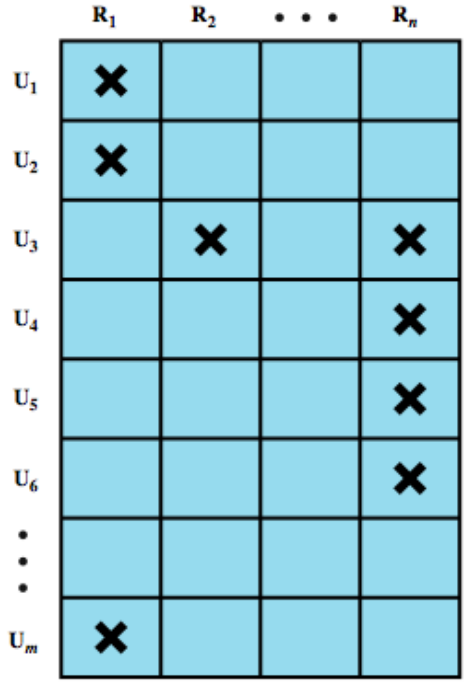


Why RBAC?

- Traditional DAC systems define the access rights of individual users and groups of users. In contrast, RBAC is based on the roles that users assume in a system rather than the user's identity.
- Typically, RBAC models define a role as a job function within an organization. RBAC systems assign access rights to roles instead of individual users. In turn, users are assigned to different roles, either statically or dynamically, according to their responsibilities. RBAC now enjoys widespread commercial use and remains an area of active research.
- The relationship of users to roles is many to many, as is the relationship of roles to resources, or system objects. The set of users changes, in some environments frequently and the assignment of a user to one or more roles may also be dynamic. The set of roles in the system in most environments is likely to be static, with only occasional additions or deletions. Each role will have specific access rights to one or more resources. The set of resources and the specific access rights associated with a particular role are also likely to change only infrequently.

Role-Based Access Control

Role-users and roles-object access matrix



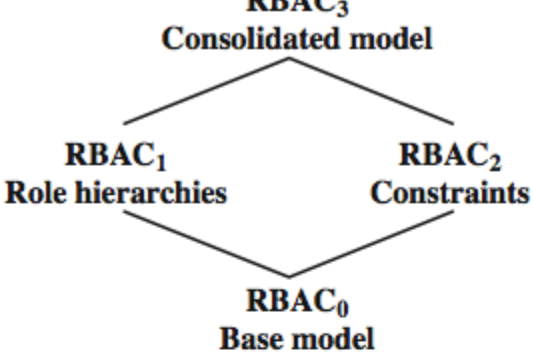
OBJECTS

ROLES	R1	R2	Rn	F1	F1	P1	P2	D1	D2
R1	control	owner	owner control	read *	read owner	wakeup	wakeup	seek	owner
R2		control		write *	execute			owner	seek *
• • •									
Rn			control		write	stop			

Role-Based Access Control

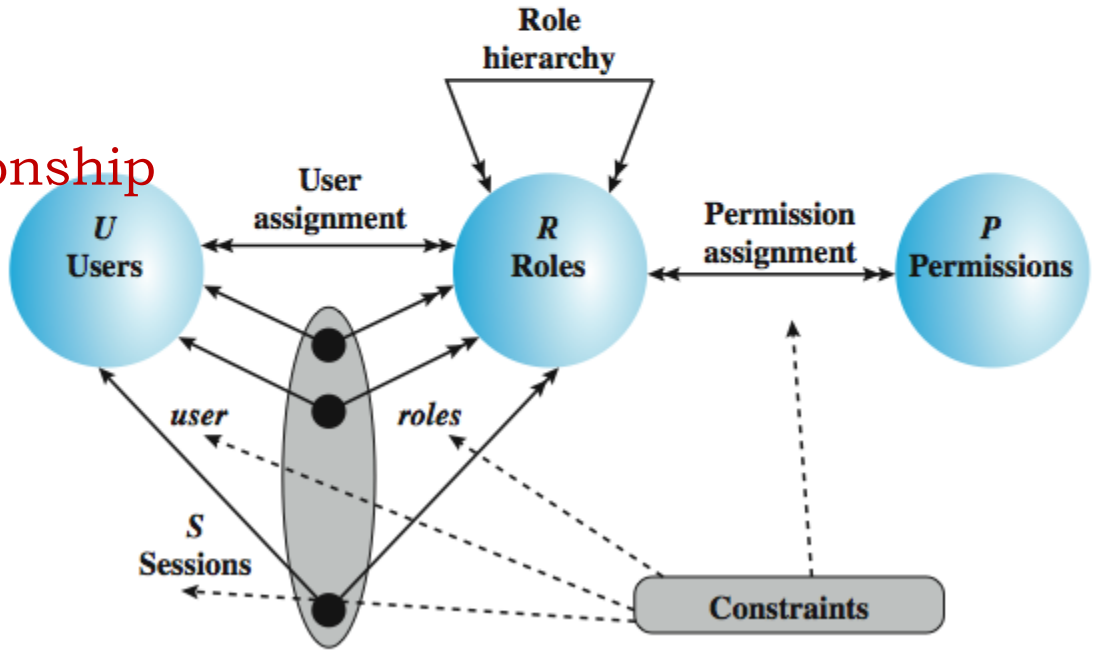
- We can use the access matrix representation to depict the key elements of an RBAC system in simple terms.
- The upper matrix relates individual users to roles. Typically there are many more users than roles. Each matrix entry is either blank or marked, the latter indicating that this user is assigned to this role. Note that a single user may be assigned multiple roles (more than one mark in a row) and that multiple users may be assigned to a single role (more than one mark in a column).
- The lower matrix has the same structure as the DAC access control matrix, with roles as subjects. Typically, there are few roles and many objects, or resources. In this matrix the entries are the specific access rights enjoyed by the roles. Note that a role can be treated as an object, allowing the definition of role hierarchies.
- RBAC lends itself to an effective implementation of the principle of least privilege. Each role should contain the minimum set of access rights needed for that role. A user is assigned to a role that enables him or her to perform only what is required for that role. Multiple users assigned to the same role, enjoy the same minimal set of access rights.

Role-Based Access Control



(a) Relationship among RBAC models

Double arrow: 'many' relationship
Single arrow: 'one' relationship



(b) RBAC models

Role-Based Access Control

A variety of functions and services can be included under the general RBAC approach. An RBAC system contains the four types of entities:

• **User:** An individuals that has access to this computer system, & associated user ID.

• **Role:** A named job function within the organization that controls this computer system. Typically, associated with each role is a description of the authority and responsibility conferred on this role, and on any user who assumes this role.

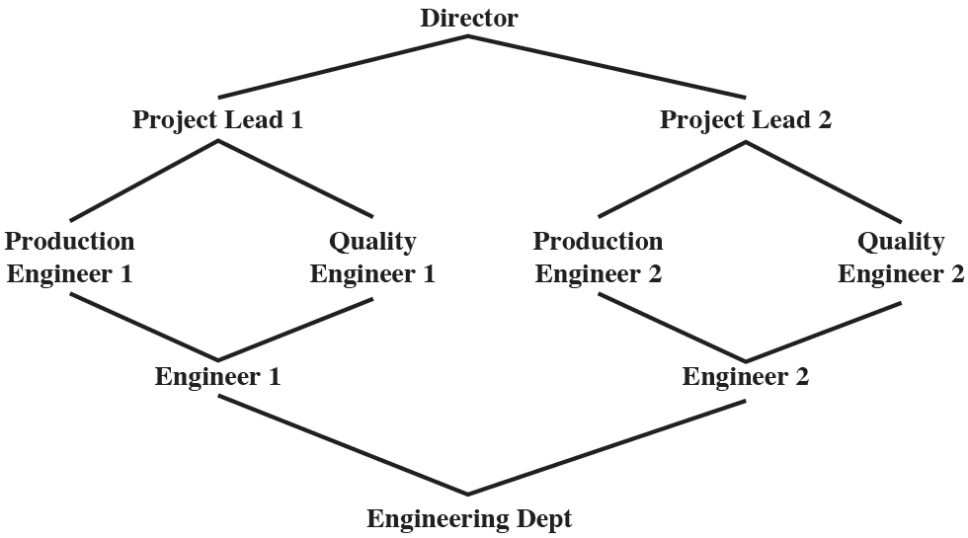
• **Permission:** An approval of a particular mode of access to one or more objects. Equivalent terms are *access right*, *privilege*, and *authorization*.

• **Session:** A mapping between a user and an activated subset of the set of roles to which the user is assigned.

The solid lines in Figure indicate relationships, or mappings, with a single arrowhead indicating one and a double arrowhead indicating many. Thus, there is a many-to-many relationship between users and roles: one user may have multiple roles, and multiple users may be assigned to a single role. Similarly, there is a many-to-many relationship between roles and permissions. See text for more details.

Example of role hierarchy

- Director has most privileges
- Each role inherits all privileges from lower roles
- A role can inherit from multiple roles
- Additional privileges can be assigned to a role



Constraints

- A condition (restriction) on a role or between roles
  - **Mutually exclusive**
    - role sets such that a user can be assigned to only one of the role in the set
    - Any permission can be granted to only one role in the set
  - **Cardinality**: set a maximum number (of users) wrt a role (e.g., a department chair role)
  - **Prerequisite role**: a user can be assigned a role only if that user already has been assigned to some other role

Attribute-based access control

- Fairly recent
- Define authorizations that express conditions on properties of both the resource and the subject
  - Each resource has an attribute (e.g., the subject that created it)
  - A single rule states ownership privileges for the creators
- Strength: its flexibility and expressive power
- Considerable interest in applying the model to cloud services

Types of attributes

- Subject attributes
- Object attributes
- Environment attributes

Subject attributes

- A subject is an active entity that causes information to flow among objects or changes the system state
- Attributes define the identity and characteristics of the subject
  - Name
  - Organization
  - Job title

Object attribute

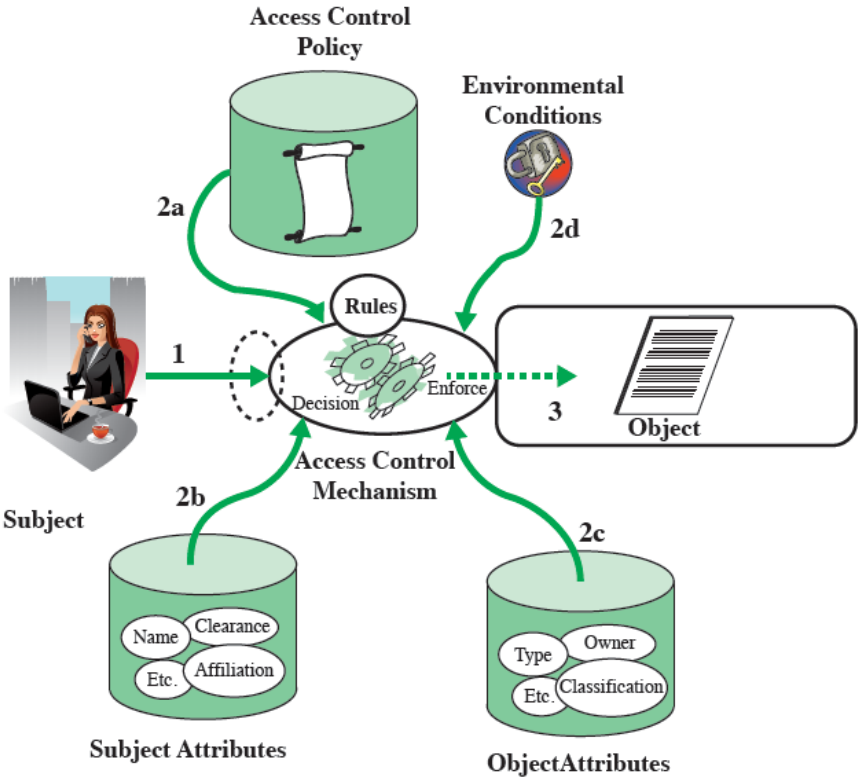
- An object (or resource) is a passive information system-related entity containing or receiving information
- Objects have attributes that can be leveraged to make access control decisions
  - Title
  - Author
  - Date

Environment attributes

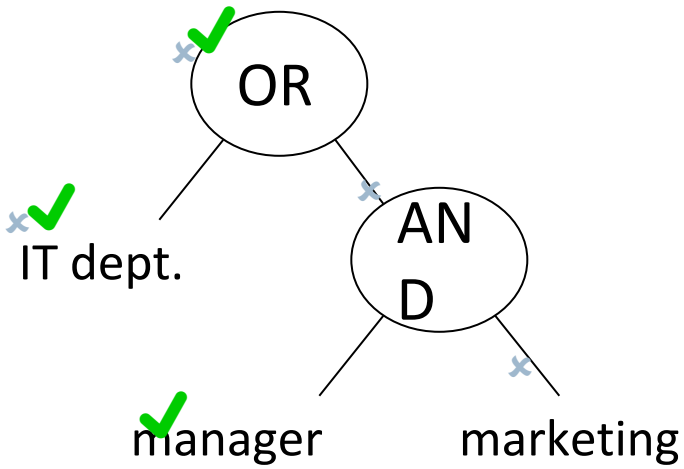
- Describe the operational, technical, and even situational environment or context in which the information access occurs
  - Current date
  - Current virus/hacker activities
  - Network security level
  - *Not associated with a resource or subject*
- These attributes have so far been largely ignored in most access control policies

Sample ABAC scenario

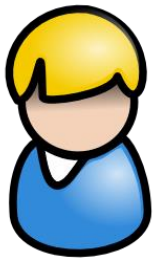
1. A subject requests access to an object
2. AC is governed by a set of rules (2a): assesses the attr of subject (2b), object (2c) and env (2d)
3. AC grants subject access to object if authorized



ABAC



SK_{Sarah}:
"manager"
"IT dept."



SK_{Kevin}:
"manager"
"sales"



Summary

Factors	DAC	MAC	RBAC	ABAC
Access Control to Information	Through owner of data	Through fixed rules	Through roles	Through attributes
Access Control Based on	Discretion of owner of data	Classification of users and data	Classification of roles	Evaluation of attributes
Flexibility for Accessing Information	High	Low	High	Very high
Access Revocation Complexity	Very complex	Very easy	Very easy	Very easy
Support for Multilevel Database System	No	Yes	Yes	Yes
Used in	Initial Unix system	The U.S. department of defense	ATLAS experiment in CERN	The Federal government